总体方案 · 2026-10-29

托管 UKey 采集平台

一套云平台，可下沉的 Agent，三种交付形态：标准托管、BYO 自带网银服务器、私有化部署。

方案范围

云平台 / 本地 Agent / MB 机柜 / 多租户

适用读者

产品、研发、运维、售前

核心原则

执行面本地，控制与数据面云上

当前阶段

P0 试点设计

本文件为内部方案，不包含客户凭据、真实账号或访问令牌。

00 文档说明

本方案把“标准托管”“客户自带网银服务器（BYO）”和“私有化部署”合并到同一套产品架构中。平台代码不分叉，差异只在于：平台部署在哪、Agent 部署在哪、UKey 归谁、凭据存哪、数据与运维边界怎么划。

> **结论先行：**推荐“云平台 + 可下沉 Agent”的架构。Agent 始终部署在 MB 机柜旁边，主动出站连云端；平台不直接连接 MB，也不直接执行 mb.exe。

目录

01 目标、边界与三种交付形态 01

02 总体架构与组件职责 02

03 MB 能力与设备信息获取 03

04 核心业务流程 04

05 租户、数据模型与端口绑定 05

06 Agent 设计与 Agent API 06

07 凭据、安全与合规 07

08 客户端 UKey 视图与运营后台 08

09 部署、运维与三种产品形态 09

10 分阶段实施与试点验收 10

11 风险、待定决策与下一步 11

右侧数字为章节编号，不是页码。

版本记录

版本	日期	说明
v1.0	2026-10-29	合并标准托管、BYO 自带网银服务器、私有化部署三种形态；设备信息获取改为本地 mb.exe 优先、服务商接口兜底。

01 目标、边界与三种交付形态

目标

- 客户不购买 UKey 服务器，也能使用平台；UKey 托管在我方机房。
- 客户已有或愿意自建网银服务器时，平台同样能接，不另做一套系统。
- 采集由本地 Agent 完成，结果和原件上传云端，客户通过浏览器查看。
- 多个客户共享 MB 机柜，但数据、端口、任务和操作严格隔离。

首版不做

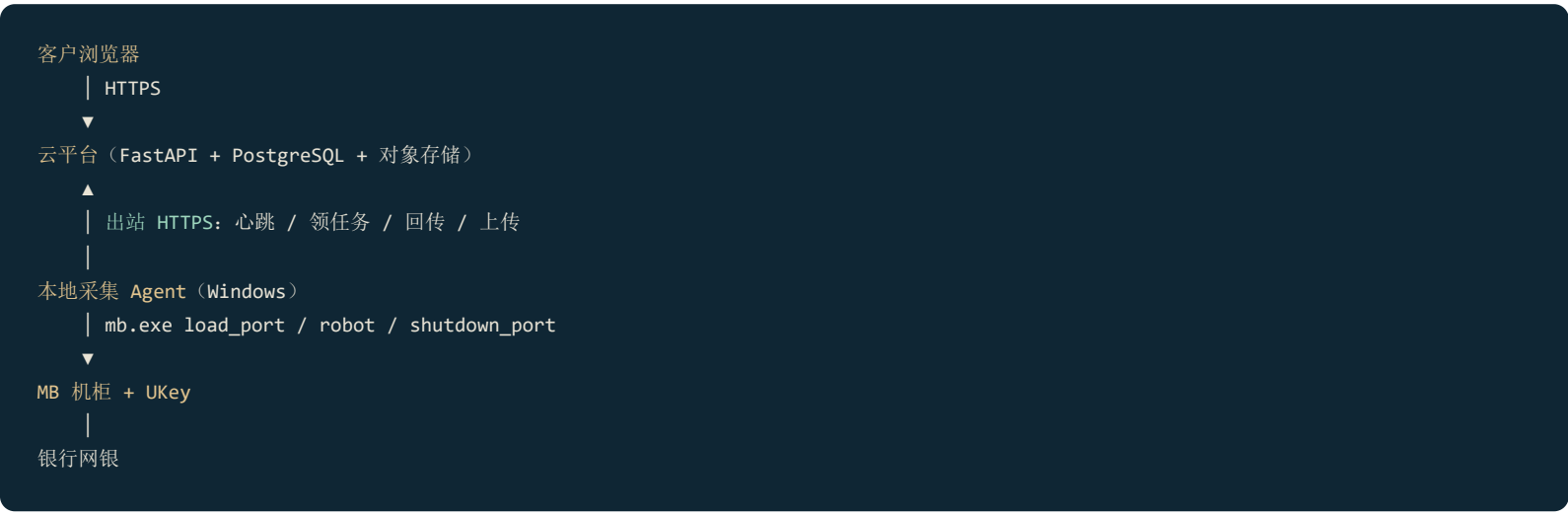
- 客户自助开通、在线支付、复杂计费。
- 跨地域多活和自动容灾。
- 客户直接操作 MB 机柜或访问本地 Agent。
- 承诺所有银行都能无人值守；按银行逐家验证。

三种交付形态

形态	平台位置	UKey / MB	适用客户	谁运维
标准托管	我方云	我方机房	不想买服务器的小客户	我方全包
BYO	我方云	客户机房	已有或愿意买 MB 的客户	客户管硬件，我方管平台
私有化	客户机房	客户机房	银行、国企、数据不出域	客户 IT，我方支持

> **不建议**：平台部署在客户机房、UKey 放在我方机房。网络方向是反的，运维和安全边界都很难划清。

02 总体架构与组件职责



Agent 可以部署在我方机房（标准托管），也可以部署在客户机房（BYO / 私有化）。云端不主动连本地，不需要客户开放入站端口。云端只负责任务、设备、数据、审计；硬件动作全部由 Agent 执行。

组件职责

组件	职责
云平台 • Web/API	客户与运营人员访问；租户隔离、权限、审计。
云平台 • 调度器	按账户采集计划生成流水/回单任务。
云平台 • 任务中心	任务队列、租约、重试、状态机、端口锁。
云平台 • 设备中心	MB 机柜、端口、UKey、租户与账户绑定。
云平台 • 数据与文件	流水、回单、余额、对账结果；原件对象存储。
本地 Agent	心跳、领任务、mb.exe 控制、采集执行、结果上传。
本地 Agent • 守护	Windows 服务、看门狗、自动重启、日志轮转、断网缓存。
MB 机柜	UKey 物理托管、端口映射、机械臂按键、端口复位。

03 MB 能力与设备信息获取

MB 实际提供的能力

- **设备标识：**ter_id（机柜）+ port（端口）唯一标识一个 UKey。
- **设备清单：**银行、客户别名、证书到期、在线/离线、端口是否插着设备、PID。
- **端口控制：**加载、拔出、强制拔出、重启端口、重启整柜。
- **机械臂：**对需要物理按键确认的 UKey 执行按键动作。

当前实现与新目标

能力	当前实现	目标
设备清单	服务商 Web 接口，F12 复刻请求，依赖登录态 token	**本地优先**：Agent 用 mb.exe status 读取，平台落库
银行/别名/证书	服务商 Web 接口	本地能拿到的用本地；拿不到的保留平台已有值，服务商接口仅兜底
端口控制	本地 mb.exe	保持一致，全部由 Agent 执行

> **已落地的调整：**设备同步已改为“本地优先、服务商兜底”。平台优先执行 mb.exe status --ter_id，解析端口、银行、USB PID、占用状态；原有别名和证书到期保留；本地不可用或缺少元数据时才回退服务商接口。同步结果会记录来源（本地 MB / 服务商接口）。

本地 status 的实际字段

字段	用途
usb_port_manage.usb_port_info[].usb_port	端口号，与平台 gf3_port 对应
bank_infos.bank_type / vendor / product	银行、厂商、UKey 型号；映射到 bank_code 和证书主题
dev_exists	端口是否插着设备；0 表示空闲
usb_share / client_ip	是否被采集机占用；对应“使用中”状态
usb_pid	设备编号，写入 external_id
port_name	端口备注；没有时用“银行 · N号口”生成名称

本地 status 不返回客户别名、证书到期时间；这些字段继续保留平台已有值，或通过服务商接口/人工维护补齐。长期应推动 MB 厂商提供本地官方 API 或 SDK，避免依赖网页登录态。

MB 动作与平台动作

时机	MB 命令	平台 / Agent 动作
新机柜接入	find_ter / get_mac	登记 ter_id、位置、所属 Agent
盘点 UKey	status --ter_id	本地读取端口、银行、占用状态
任务开始	force_shutdown_port	清理上一次异常残留
加载 UKey	load_port --ter_id --port --user	等待系统识别 UKey
需要按键	robot --ter_id --port	银行流程对应步骤调用
任务结束	shutdown_port	无论成功失败都释放端口
端口卡死	force_shutdown_port	兜底并告警
单端口异常	restart_port	自动恢复一次
整柜异常	restart_ter	运营确认后执行

04 核心业务流程

UKey 入库与绑定

1. 客户寄送 UKey，登记客户、银行、账户、证书到期。
2. 插入 MB 机柜指定 ter_id + port。
3. Agent 读取本地 status，平台写入或更新 UKey 设备。
4. 绑定客户账户；一个 UKey 只服务一个租户的一个账户。
5. 生成托管凭证：机柜位置、端口、照片、入库时间。

采集任务

1. 云端调度器按 collect_cron 创建任务。

2. 任务带 tenant_id、账户、设备、ter_id、端口。

3. Agent 领取任务并锁定端口。

4. Agent 执行：清理残留 → load_port → 等待识别 → 浏览器与银行驱动 → 需要时 robot → 采集 → shutdown_port。

5. 上传结果 JSON、日志、原件。

6. 云端幂等入库，更新余额、流水、回单、任务状态。

7. 客户查看；失败进入待办。

失败处理

场景	处理
端口卡死	force_shutdown_port
单端口异常	restart_port
整柜异常	restart_ter
Agent 崩溃	租约过期，备用 Agent 接管；先强制释放端口
银行页面异常	重试 1–3 次，仍失败标记“需处理”
OTP / 人工确认	标记“半自动”，进入人工处理队列

05 租户、数据模型与端口绑定

核心表

表	关键字段
tenant	名称、编码、deployment_mode、状态、套餐
app_user	tenant_id、role：管理员 / 财务 / 审计
agent	code、tenant_id（BYO 必填）、deployment_mode、机柜列表、状态、心跳
mb_terminal	ter_id、owner、位置、主/备 Agent、端口数、状态
ukey_device	tenant_id、ter_id、port、bank_code、alias、cert_expires_at、status、assigned_account_id、is_spare
bank_account	tenant_id、ukey_device_id、collect_cron、watermark_date
collection_task	tenant_id、account_id、device_id、agent_code、type、status、lease_until
artifact	tenant_id、object_key、kind、sha256、size
audit_log	tenant_id、actor、action、target、detail

约束

- 一个 ter_id + port 同时只绑定一个 UKey。
- 一个 UKey 同时只服务一个账户。
- 一个端口同时只有一个进行中的任务。

- 备用端口单独标记，不参与正常调度。
- 所有查询必须带 tenant_id，不能只靠前端隐藏。

06 Agent 设计与 Agent API

Agent 是部署边界

- Windows 服务、开机自启、看门狗、自动重启。
- 安装 mb.exe、Chrome、银行驱动、AiKeyboard。
- 与 MB 同局域网，出站 HTTPS 到云端。
- 只允许访问：云端域名、MB 地址、银行域名。
- 一次性注册码绑定租户/机柜；支持签名升级和回滚。
- 断网时保留已领取任务，继续执行；新任务等恢复后再领。

Agent API（当前已实现）

接口	作用
POST /api/agent/devices/report	上报 MB 设备、端口、银行与占用状态
POST /api/agent/tasks/claim	按 agent_code 领取本机队列任务，30 分钟租约
GET /api/agent/tasks/{id}/credentials	领取后单独获取账户凭据，不放在任务列表里
POST /api/agent/tasks/{id}/result	回传执行结果、日志与原件（base64）

注意：Agent 只主动出站访问平台，平台不连客户内网；令牌通过 PLATFORM_AGENT_TOKEN_MAP 绑定到具体 agent_code，一个令牌不能领取其他 Agent 的任务。回传原件单文件上限 20MB、单任务上限 60MB。

07 凭据、安全与合规

凭据两种模式

模式	做法	适用
云端托管（默认）	密码/PIN 加密存云端 KMS，Agent 执行时取一次性凭据	标准托管；体验好，支持远程排障
本地保管	凭据加密存采集盒子本地，云端只发任务、不收密码	BYO / 私有化；强合规客户

必做安全项

- 云端 HTTPS、Secure Cookie、CSRF、登录限流、会话过期、MFA。
- Agent Token / 证书，支持轮换；可选 mTLS。
- Agent 出站白名单；不开放入站。
- 云端按租户加密；KMS/信封加密。
- 每次凭据解密、端口加载/释放、人工操作都写审计。
- 银行授权书、数据处理协议、数据保留/删除策略。
- 本地机柜：锁柜、门禁、监控、UPS、备用端口、UKey 进出登记。

08 客户端 UKey 视图与运营后台

客户可见

- 银行、账户尾号、户名
- 托管位置：我方机房 / 客户机房
- 状态：在线 / 离线 / 维护中
- 证书到期时间
- 最近采集、最近插拔/按键
- 操作记录
- “申请更换” “报障”

运营可见

- ter_id、端口、PID、Agent
- 端口占用、异常状态
- restart_port / restart_ter / force_shutdown_port
- 物理位置、备用端口
- 设备离线、证书到期、任务失败率
- Agent 心跳、队列积压

客户不需要访问 MB 后台。平台提供“托管 UKey”页面，把技术细节收敛为客户能理解的状态和记录。

09 部署、运维与三种产品形态

部署拓扑

形态	云端	本地	网络
标准托管	FastAPI + PostgreSQL + MinIO/S3 + Nginx	MB 机柜 + 采集机	本地出站 443
BYO	同一套云平台	客户 MB + 采集盒子（Windows 迷你主机）	客户出站 443
私有化	无	平台 + Agent + PostgreSQL + MinIO	客户内网 / 离线

采集盒子

BYO 场景建议提供预配置的 Windows 迷你主机：Agent、mb.exe、Chrome、银行驱动、AiKeyboard、看门狗全部预装。客户只需提供电源、网口，把 UKey 插进机柜。比在客户 IT 机器上装软件更可控，也更容易远程支持。

运营与支持边界

形态	硬件 / 物理	平台 / Agent	SLA 重点
标准托管	我方	我方	全链路
BYO	客户	我方	平台与 Agent；不含客户网络/硬件
私有化	客户	客户 IT，我方支持	License 与版本支持

10 分阶段实施与试点验收

实施阶段

阶段	时间	交付
P0 标准托管试点	2–3 周	Agent API、独立 Agent、MB 端口控制、单客户云端平台、结果上传
P1 产品化	4–6 周	租户隔离、BYO 采集盒子、注册码、运营后台、对象存储、监控告警、备份
P2 规模化	6–8 周	多 Agent、备用机柜、自动升级、SLA 监控、计费
P3 私有化	4–6 周	离线安装包、License、本地对象存储、备份、实施手册

每接一家新银行，另算 1–3 周，取决于 UKey、OTP、页面稳定性和是否需要 robot 按键。按 2 名工程师 + 0.5 名运维估算，实际取决于银行数量。

P0 只做四件事

1. 把 Worker 从平台进程拆成独立 Agent。
2. 增加 /api/agent/*。
3. 把 MB 的 ter_id + port 绑定到账户，任务开始/结束走 load_port / shutdown_port，异常走 force_shutdown_port / restart_port。
4. 选 1–2 家真实银行，验证采集、按键、证书、PIN。

试点验收标准

- 1 个客户、1 台 MB、2 家银行。
- 定时任务成功率 ≥ 95%。
- 端口释放率 100%，无残留映射。
- Agent 重启后能继续领任务。
- 端口卡死可通过 force_shutdown_port 恢复。
- 设备离线、证书到期、任务失败都有告警。
- 客户只能看到自己的数据。
- 记录每家银行的 UKey 按键、PIN、OTP 限制。

11 风险、待定决策与下一步

关键风险

风险	应对
厂商 Web 接口 token 过期/改版	设备库存改为 Agent 本地上报，云端缓存；服务商接口仅兜底
MB 机械臂不兼容某些 UKey	按银行逐一验证 robot 动作
银行 OTP / 人工确认	定义“半自动”流程，不承诺全自动
单台 MB / Agent 故障影响多客户	备用端口、备用采集机、租约接管
租户隔离漏洞	统一 tenant_id、自动化隔离测试、代码审查
客户本地网络限制出站	提供私有化部署 SKU
凭据泄露	KMS、短期凭据、审计、最小权限

需要先定的决策

1. 云端默认共享多租户，还是每客户独立实例?
2. BYO 客户用采集盒子，还是允许装在他们自己的 Windows 机器?
3. 凭据默认放云端 KMS，还是本地保管?
4. 首批做哪几家银行?
5. 断网时本地是否继续执行已领取任务?
6. 三种形态的 SLA、硬件归属和收费边界。

> **当前落地状态（2026-10-29）：** 设备同步已改为本地优先：平台优先执行 mb.exe status，解析端口、银行、PID、占用状态；原有别名和证书保留，本地不可用时回退服务商接口。已在真实 MB 上验证 29 台设备同步，来源标记为“本地 MB”。客户侧设备上报通道和任务下发通道已实现：Agent 主动领取本机任务、单独获取凭据、执行后回传结果与原件；令牌按 agent_code 绑定。桌面控制台已完成设备上报与任务执行两项联调。测试 98 passed / 2 skipped。

建议下一步

先做 P0 标准托管试点：1 个客户、1 台 MB、1 台采集机、2 家银行。把 Agent API、独立 Agent、MB 端口控制、结果上传跑通，再投入租户隔离和 BYO 盒子。这样既能验证最关键的银行/UKey 兼容性，也不会一开始就陷入多租户、私有化和 BYO 三条线同时开工。